

AI Critique — HW06 — 23127152

AI sinh bộ FR-05/FR-11/FR-15 khá đầy domain và schema, nhưng sai hoặc thiếu đúng chỗ bài cần: **oracle bảo mật cụ thể**. Với FR-05, Step C chỉ nêu payload SQLi cổ điển và kỳ vọng “không dump catalog”, không viết so sánh số dòng baseline (TC-A1-E03), không encode URL (TC-A1-E01), và không assert Content-Type=<h1>Database Error trên kênh lỗi (TC-A1-E02/E06). Newman sau đó fail đúng vì SUT nối chuỗi SQL — nhưng nếu chỉ tin mô tả định tính của AI thì khó chứng minh bug. Với FR-11, AI nói “không lộ PII” mà không neo vào field shipping_address của nạn nhân; extended TC-B2-E01 mới biến IDOR thành assert đo được và dẫn tới [#302](#). Với FR-15, model viết expected 401/403 theo spec nhưng không nhấn “200 + tạo thành công khi không JWT” như oracle lỗi; phải đọc server.js (không authenticateToken) mới thành BUG-ADMINPROD-001 [#303](#).

Nguyên nhân chính: prompt dựa spec chung, thiếu nguồn SUT và thiếu yêu cầu “mỗi SEC case phải có oracle quan sát được”; model ưu tiên danh sách payload quen thuộc hơn chuỗi kiểm chứng. Audit AI cũng dễ gán VALID khi expected còn mơ hồ.

Bài học: cộng tác AI trong API testing nghĩa là dùng nó để **đề xuất ứng viên TC**, rồi human audit/extend buộc mỗi security claim thành assert so sánh được trước khi chạy Newman. Số fail trên report chỉ đáng tin khi expected đã chốt theo spec, không theo hành vi lỗi hiện tại của SUT.

Word count: 271